

Security Scan Report

Target: http://127.0.0.1:5001

Scan Date: July 23, 2026 at 14:55 UTC

Scan ID: 7d02054e-6808-4632-b94a-897d84f88dc4

0 CRITICAL

4 HIGH

3 MEDIUM

3 LOW

Executive Summary

Security scan of 'http://127.0.0.1:5001' identified 19 raw findings, reduced to 10 unique issues after deduplication. ■ 4 HIGH-severity issue(s) should be prioritized for remediation within the next 48 hours. 3 MEDIUM-priority issue(s) should be addressed in the current development sprint. 3 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	19
After Deduplication	10
Critical Findings	0
High Findings	4
Medium Findings	3
Low Findings	3
Scan Duration	10.0s

Detailed Findings

[HIGH] #1: Missing Auth in admin:0

Risk Score	0.6839
Affected Location	http://127.0.0.1:5001/admin:0
Vulnerability Type	MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation
This endpoint or function lacks authentication, allowing unauthenticated users to access protected resources. Found in admin. Admin panel may be accessible without proper authentication.

Code or HTTP Excerpt

```
1 | GET /admin → HTTP 200
2 | Content-Length: 1341 bytes
3 | Preview: <!DOCTYPE html>
4 | <html>
5 | <head>
6 |   <title>VulnApp - Admin</title>
7 | </head>
8 | <body style="font-family: Arial, sans-serif; max-width: 900px; margin: 0 auto
```

Business Impact
Unauthenticated users could access the admin panel, potentially viewing or modifying sensitive data without authorization.

Fix Recommendation
Rule-based recommendation: Add authentication middleware or decorators to all sensitive endpoints. Verify user identity before serving protected data.

[HIGH] #2: Information Disclosure in .env:0

Risk Score	0.6063
Affected Location	http://127.0.0.1:5001/.env:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing sensitive information that could help attackers plan targeted attacks. Found in .env. Exposed.

Code or HTTP Excerpt

```
1 | GET /.env → HTTP 200
2 | Content-Length: 66 bytes
3 | Preview: DB_PASSWORD=admin123
4 | SECRET_KEY=mysecretkey
5 | API_KEY=sk-1234567890
```

Business Impact

The disclosed user credentials and passwords helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Block access to .env files in your web server config. In nginx: location ~ /\.env { deny all; }. In Apache: <FilesMatch "\.env"> Require all denied </FilesMatch>.

[HIGH] #3: Information Disclosure in backup.sql:0

Risk Score	0.6063
Affected Location	http://127.0.0.1:5001/backup.sql:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-530
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in backup.sql. Database backup file is publicly accessible — critical data exposure.

Code or HTTP Excerpt

```
1 | GET /backup.sql → HTTP 200
2 | Content-Length: 138 bytes
3 | Preview: -- MySQL dump
4 | CREATE TABLE users (id INT, username VARCHAR(50), password VARCHAR(50));
5 | INSERT INTO users VALUES (1, 'admin', 'admin123');
```

Business Impact

The disclosed user credentials and passwords helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove database backup files from the web root. Store backups in a non-web-accessible directory. Add rules to deny access to *.sql, *.bak, *.dump file extensions.

[HIGH] #4: Insecure Transport in 127.0.0.1:5001:0

Risk Score	0.5700
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INSECURE_TRANSPORT
CWE ID	CWE-319
Detected By	url-scanner

Explanation

The site is served over unencrypted HTTP, exposing all traffic to interception. Found in 127.0.0.1:5001. Site is served over plain HTTP.

Business Impact

All data transmitted to user session data — including passwords and session tokens — can be intercepted on the network.

Fix Recommendation

Rule-based recommendation: Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP traffic to HTTPS. Add the HSTS header.

[MEDIUM] #5: Xss in search?q=:0

Risk Score	0.5141
Affected Location	http://127.0.0.1:5001/search?q=:0
Vulnerability Type	XSS
CWE ID	CWE-79
Detected By	url-scanner

Explanation

Cross-Site Scripting (XSS) allows attackers to inject malicious scripts into web pages viewed by other users. Found in search?q=. Reflected XSS detected via parameter 'q'.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/search?q=javascript%3Aalert%281%29
2 | Payload: q=javascript:alert(1)
3 | Reflection found in response body
```

Business Impact

An attacker could steal session tokens from authenticated users, redirect users to phishing pages, or perform actions as the victim.

Fix Recommendation

Rule-based recommendation: Apply context-aware output encoding before rendering user content. Use your framework's built-in auto-escaping.

[MEDIUM] #6: Information Disclosure in config:0

Risk Score	0.4462
Affected Location	http://127.0.0.1:5001/.git/config:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-538
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in config. Exposed.

Code or HTTP Excerpt

```
1 | GET /.git/config → HTTP 200
2 | Content-Length: 115 bytes
3 | Preview: [core]
```

```
4 | ■repositoryformatversion = 0
5 | ■bare = false
6 | [remote "origin"]
7 | ■url = https://github.com/user/secret-repo.git
```

Business Impact

The disclosed Git repository metadata and history helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Block access to .git/ directory in your web server config. In nginx: location ~ /\.git { deny all; }. Remove the .git directory from the deployed artifact.

[MEDIUM] #7: Information Disclosure in robots.txt:0

Risk Score	0.4220
Affected Location	http://127.0.0.1:5001/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in robots.txt. robots.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 65 bytes
3 | Preview: User-agent: *
4 | Disallow: /admin
5 | Disallow: /backup
6 | Disallow: /.env
```

Business Impact

The disclosed database backup files helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Review robots.txt for sensitive path disclosure. While robots.txt is public, listing hidden paths like /admin or /backup reveals targets to attackers. Use authentication instead of obscurity.

[LOW] #8: Insecure Cookie in 127.0.0.1:5001:0

Risk Score	0.3920
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INSECURE_COOKIE
CWE ID	CWE-1004
Detected By	url-scanner

Explanation

One or more cookies are missing important security flags, making them vulnerable to theft or misuse. Found in 127.0.0.1:5001. Session cookie 'session_id' is missing the HttpOnly flag.

Code or HTTP Excerpt

```
1 | Set-Cookie: session_id=abc123; Path=/
```

Business Impact

The user session data cookie could be stolen via XSS or transmitted over insecure connections, enabling session hijacking.

Fix Recommendation

Rule-based recommendation: Set Secure, HttpOnly, and SameSite=Lax on the session cookie. In Flask: `app.config['SESSION_COOKIE_SECURE'] = True; app.config['SESSION_COOKIE_HTTPONLY'] = True; app.config['SESSION_COOKIE_SAMESITE'] = 'Lax'.`

[LOW] #9: Clickjacking in 127.0.0.1:5001:0

Risk Score	0.3589
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	CLICKJACKING
CWE ID	CWE-1021
Detected By	url-scanner

Explanation

The page can be embedded in an iframe, allowing attackers to overlay invisible controls and trick users into clicking. Found in 127.0.0.1:5001. Missing X-Frame-Options header.

Code or HTTP Excerpt

```
1 | Response headers: X-Frame-Options = (not set)
```

Business Impact

Users could be tricked into performing unintended actions on your application such as changing settings or transferring funds.

Fix Recommendation

Rule-based recommendation: Add X-Frame-Options: DENY header or use Content-Security-Policy with frame-ancestors 'self'.

[LOW] #10: Information Disclosure in 127.0.0.1:5001:0

Risk Score	0.1960
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing sensitive information that could help attackers plan targeted attacks. Found in 127.0.0.1:5001. X-Powered-By header discloses technology stack: 'Flask/2.

Code or HTTP Excerpt

```
1 | X-Powered-By: Flask/2.0.1 Python/3.10.0
```

Business Impact

The disclosed server technology stack (via X-Powered-By header) helps attackers identify attack vectors, reducing the effort needed for a successful breach.

Fix Recommendation

Rule-based recommendation: Remove the X-Powered-By header from responses. In Express: `app.disable('x-powered-by')`. In Flask: `del response.headers['X-Powered-By']`.

Appendix

Deduplication Statistics

Total raw findings: 19 | After deduplication: 10 | Reduction: 47%

Scan Metadata

Scan ID	7d02054e-6808-4632-b94a-897d84f88dc4
Target	http://127.0.0.1:5001
Timestamp	2026-07-23T14:55:47.035554+00:00
Duration	10.0s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "d79bcc60-dba4-4eea-b205-f7c67634d836",
    "title": "Missing Auth in admin:0",
    "file": "http://127.0.0.1:5001/admin",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "MISSING_AUTH",
    "description": "Admin panel may be accessible without proper authentication.",
    "rule_id": "sensitive-path-admin",
    "confidence": 0.85,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "GET /admin \u2192 HTTP 200\nContent-Length: 1341 bytes\nPreview: <!DOCTYPE html>\n<html>\n</html>\n",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.6839,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "This endpoint or function lacks authentication, allowing unauthenticated users to access sensitive information.",
    "fix_suggestion": "Add authentication middleware or decorators to all sensitive endpoints. Verify user identity before processing requests.",
    "business_impact": "Unauthenticated users could access the admin panel, potentially viewing or modifying sensitive data.",
    "raw": {
      "url": "http://127.0.0.1:5001/admin",
      "status": 200,
      "path": "/admin"
    }
  },
  {
    "id": "42af02c2-b85c-4746-b2b7-28dec799932d",
    "title": "Information Disclosure in .env:0",
    "file": "http://127.0.0.1:5001/.env",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Sensitive information (API keys, database credentials) is exposed in the .env file.",
    "rule_id": "env-file-disclosure",
    "confidence": 0.9,
    "cwe_id": "CWE-264",
    "cvss_score": 9.1,
    "code_snippet": ".env\nAPI_KEY=sk-1234567890\nDB_PASSWORD=secret123\n",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.9,
    "risk_category": "CRITICAL",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The .env file contains sensitive information that should not be committed to version control or exposed to the public.",
    "fix_suggestion": "Remove sensitive information from the .env file and use environment variables or secure storage.",
    "business_impact": "Sensitive information (API keys, database credentials) is exposed, potentially leading to data breaches or unauthorized access.",
    "raw": {
      "url": "http://127.0.0.1:5001/.env",
      "status": 200,
      "path": "/.env"
    }
  }
]
```

```

    "description": "Exposed .env file \u2014 may contain secrets, API keys, and database credentials.",
    "rule_id": "sensitive-path-.env",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /.env \u2192 HTTP 200\nContent-Length: 66 bytes\nPreview: DB_PASSWORD=admin123\nSE",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.6063,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
    "fix_suggestion": "Block access to .env files in your web server config. In nginx: location ~ /\.env {",
    "business_impact": "The disclosed user credentials and passwords helps attackers identify attack vectors",
    "raw": {
        "url": "http://127.0.0.1:5001/.env",
        "status": 200,
        "path": "/.env"
    }
},
{
    "id": "824ba272-71ca-42a2-8525-5ccfdc3a97a1",
    "title": "Information Disclosure in backup.sql:0",
    "file": "http://127.0.0.1:5001/backup.sql",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Database backup file is publicly accessible \u2014 critical data exposure.",
    "rule_id": "sensitive-path-backup.sql",
    "confidence": 0.85,
    "cwe_id": "CWE-530",
    "cvss_score": null,
    "code_snippet": "GET /backup.sql \u2192 HTTP 200\nContent-Length: 138 bytes\nPreview: -- MySQL dump\nCRE",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.6063,
    "risk_category": "HIGH",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
    "fix_suggestion": "Remove database backup files from the web root. Store backups in a non-web-accessible",
    "business_impact": "The disclosed user credentials and passwords helps attackers identify attack vectors",
    "raw": {
        "url": "http://127.0.0.1:5001/backup.sql",
        "status": 200,
        "path": "/backup.sql"
    }
},
{
    "id": "6e7abd82-636e-43b2-8338-0c177da02116",
    "title": "Insecure Transport in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "INSECURE_TRANSPORT",
    "description": "Site is served over plain HTTP. All traffic including credentials and session tokens is",
    "rule_id": null,
    "confidence": 1.0,
    "cwe_id": "CWE-319",
    "cvss_score": null,
    "code_snippet": null,
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.57,
    "risk_category": "HIGH",

```

```

"category_source": "score",
"category_reason": "score-threshold",
"llm_explanation": "The site is served over unencrypted HTTP, exposing all traffic to interception. Four",
"fix_suggestion": "Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP",
"business_impact": "All data transmitted to user session data \u2014 including passwords and session tok",
"raw": {
  "url": "http://127.0.0.1:5001",
  "check": "insecure_transport"
}
},
{
  "id": "b72b0d2b-2f1b-40c5-811e-db10171f5daf",
  "title": "Xss in search?q=:0",
  "file": "http://127.0.0.1:5001/search?q=",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "XSS",
  "description": "Reflected XSS detected via parameter 'q'. The payload 'javascript:alert(1)' was reflecte",
  "rule_id": "xss-reflected",
  "confidence": 0.85,
  "cwe_id": "CWE-79",
  "cvss_score": null,
  "code_snippet": "Request: GET http://127.0.0.1:5001/search?q=javascript%3Aalert%281%29\nPayload: q=java",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.5141,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "Cross-Site Scripting (XSS) allows attackers to inject malicious scripts into web pag",
  "fix_suggestion": "Apply context-aware output encoding before rendering user content. Use your framework",
  "business_impact": "An attacker could steal session tokens from authenticated users, redirect users to p",
  "raw": {
    "url": "http://127.0.0.1:5001/search?q=",
    "param": "q",
    "payload": "javascript:alert(1)",
    "reflected": true
  }
},
{
  "id": "e81f4b1b-d34a-4c88-94c5-5cfdb3d0f2eb",
  "title": "Information Disclosure in config:0",
  "file": "http://127.0.0.1:5001/.git/config",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "Exposed .git directory \u2014 source code and commit history are publicly accessible.",
  "rule_id": "sensitive-path-.git-config",
  "confidence": 0.85,
  "cwe_id": "CWE-538",
  "cvss_score": null,
  "code_snippet": "GET /.git/config \u2012 HTTP 200\nContent-Length: 115 bytes\nPreview: [core]\n\ntreposit",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4462,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "Block access to .git/ directory in your web server config. In nginx: location ~ /\u002e\u002e",
  "business_impact": "The disclosed Git repository metadata and history helps attackers identify attack ve",
  "raw": {
    "url": "http://127.0.0.1:5001/.git/config",
    "status": 200,
    "path": "/.git/config"
  }
},
},

```

```

{
  "id": "9c6cc6fa-3253-421c-9287-4c93eacb8a0f",
  "title": "Information Disclosure in robots.txt:0",
  "file": "http://127.0.0.1:5001/robots.txt",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INFORMATION_DISCLOSURE",
  "description": "robots.txt may reveal hidden paths and sensitive directories.",
  "rule_id": "sensitive-path-robots.txt",
  "confidence": 0.85,
  "cwe_id": "CWE-200",
  "cvss_score": null,
  "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 65 bytes\nPreview: User-agent: *\nDis",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.422,
  "risk_category": "MEDIUM",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted",
  "fix_suggestion": "Review robots.txt for sensitive path disclosure. While robots.txt is public, listing",
  "business_impact": "The disclosed database backup files helps attackers identify attack vectors, reduc",
  "raw": {
    "url": "http://127.0.0.1:5001/robots.txt",
    "status": 200,
    "path": "/robots.txt"
  }
},
{
  "id": "84623a89-ba4b-4cb7-b926-593dae107524",
  "title": "Insecure Cookie in 127.0.0.1:5001:0",
  "file": "http://127.0.0.1:5001",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "INSECURE_COOKIE",
  "description": "Session cookie 'session_id' is missing the HttpOnly flag. It can be accessed by JavaScr",
  "rule_id": "cookie-missing-httponly",
  "confidence": 0.9,
  "cwe_id": "CWE-1004",
  "cvss_score": null,
  "code_snippet": "Set-Cookie: session_id=abc123; Path=/",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.392,
  "risk_category": "LOW",
  "category_source": "score",
  "category_reason": "score-threshold",
  "llm_explanation": "One or more cookies are missing important security flags, making them vulnerable to",
  "fix_suggestion": "Set Secure, HttpOnly, and SameSite=Lax on the session cookie. In Flask: app.config['S",
  "business_impact": "The user session data cookie could be stolen via XSS or transmitted over insecure co",
  "raw": {
    "url": "http://127.0.0.1:5001",
    "cookie": "session_id"
  }
},
{
  "id": "39e30228-01ba-4028-83ef-6ab7e88d410b",
  "title": "Clickjacking in 127.0.0.1:5001:0",
  "file": "http://127.0.0.1:5001",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "CLICKJACKING",
  "description": "Missing X-Frame-Options header. The site may be vulnerable to clickjacking attacks where",
  "rule_id": "header-missing-x-frame-options",
  "confidence": 0.85,
  "cwe_id": "CWE-1021",

```

```

    "cvss_score": null,
    "code_snippet": "Response headers: X-Frame-Options = (not set)",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.3589,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The page can be embedded in an iframe, allowing attackers to overlay invisible content.",
    "fix_suggestion": "Add X-Frame-Options: DENY header or use Content-Security-Policy with frame-ancestors.",
    "business_impact": "Users could be tricked into performing unintended actions on your application such as logging out or changing their password.",
    "raw": {
        "url": "http://127.0.0.1:5001",
        "header": "X-Frame-Options",
        "check": "missing_header"
    }
},
{
    "id": "288d02cc-9050-45f8-b821-d0e0a8691b66",
    "title": "Information Disclosure in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "X-Powered-By header discloses technology stack: 'Flask/2.0.1 Python/3.10.0'. Remove this header to reduce information leakage.",
    "rule_id": "info-x-powered-by",
    "confidence": 0.9,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "X-Powered-By: Flask/2.0.1 Python/3.10.0",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.196,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing sensitive information that could help attackers plan targeted attacks.",
    "fix_suggestion": "Remove the X-Powered-By header from responses. In Express: app.disable('x-powered-by').",
    "business_impact": "The disclosed server technology stack (via X-Powered-By header) helps attackers identify vulnerabilities and plan attacks.",
    "raw": {
        "url": "http://127.0.0.1:5001",
        "header": "X-Powered-By",
        "value": "Flask/2.0.1 Python/3.10.0"
    }
}
]

```